



Concierge Security Assessment



DIAGNÓSTICO DE RISCO DA NUTRIN GROUP

Ambiente: Nutrin Group

Contato: Evanderson Silva Head de Tecnologia



Maturidade de Segurança Consolidada

SCORE GERAL DO AMBIENTE

Atenção

Avaliado sobre 3 domínios essenciais de infraestrutura.

 COMO CHEGAMOS NESSE SCORE?

Prioridade: Firewall / Rede

Dentre os vetores diagnosticados, o escopo **Firewall / Rede** representa a frente mais vulnerável e apresenta a menor maturidade técnica atualmente. Seu score base é 48/100.



Consequência Prática

A fragilidade crônica neste componente permite que ameaças bypassen defesas, estabelecendo um "ponto único de falha" inicial para a cadeia de ataque. Antes de ramificar orçamentos, focar estrategicamente na mitigação desta superfície deve ser a principal diretriz.

Exposição Financeira Estimada (ALE)

R\$ 67.500

Estimativa de risco cibernético financeiro anual (Probabilidade x Impacto).

Faixa referencial de custo por incidente grave: Entre R\$ 150.000 e R\$ 500.000

- **Impacto Operacional:** Paralisa abrupta de sistemas críticos como ERPs judiciais e fiscais.
- **Perda de Produtividade:** Despesa-base imobilizada em até 90 colaboradores inativos na folha de pagamento durante o "downtime".
- **Recuperação e Forense:** Custos inflacionados com consultoria especialista, negociação legal e reconstrução de TI corrompida.

 Por que o seu ambiente recebeu esse Score?

Ao identificar a falta dos controles a seguir, os modelos das agências (NIST / CIS) consideram o ambiente severamente ofuscado:

ENDPOINT Ausência de EDR (Detecção Comportamental)

A ausência de detecção e resposta em endpoints (EDR) deixa o ambiente vulnerável a ataques fileless e comportamentos anômalos que burlam antivírus tradicionais.

Fonte: CrowdStrike Global Threat Report 2025.

ENDPOINT Falta de Monitoramento Contínuo (SOC 24/7)

Ameaças cibernéticas não respeitam horário comercial. Sem monitoramento 24x7, o tempo de permanência do atacante aumenta.

Fonte: IBM Cost of a Data Breach.



ENDPOINT Ausência de MFA (Múltiplo Fator)

Ataques de roubo de credenciais são o vetor inicial em 80% dos incidentes. A falta de MFA torna o ambiente vulnerável.

Fonte: Verizon DBIR 2024.

ENDPOINT Ausência de Capacidade de Resposta Ativa

Detectar não é suficiente. Sem um plano e equipe para resposta imediata, o impacto do ataque é inevitável.

Fonte: NIST Cybersecurity Framework.

🎯 Cenários de Risco no Seu Ambiente (Kill Chain)

Com base nas vulnerabilidades sistêmicas identificadas, estes são os fluxos predatórios mais prováveis de comprometer sua operação nos moldes atuais:



Ataque de Ransomware

Criptografia em massa de dados críticos e servidores, paralisando a operação. Vetor inicial frequentemente se aproveita de falhas em endpoint de usuário ou conexões de rede desprotegidas.



Vazamento de Dados

Exfiltração silenciosa de informações confidenciais corporativas. Ocorre tipicamente pela ausência de inspeção SSL de tráfego e falta de visibilidade / logs.



Roubo de Credenciais

Ataques de força bruta contra VPNs ou contas privilegiadas. Facilitado ativamente pela ausência de múltiplo fator (MFA) efetivo nos pontos de acesso externo.

📄 Exposição Regulatória (LGPD)

A falha na proteção não resulta apenas em ataque digital, mas infração das obrigações civis exigidas no Brasil:

Art. 46

Segurança Técnica Adequada

A ausência de prevenção efetiva de ponta-a-ponta (como MFA em conexões, criptografia inter-vilan e EDR comportamental) fere a exigência de proteção contínua sobre dados pessoais de clientes e fornecedores.

Art. 48

Comunicação de Incidentes (DPO)

A falha de visibilidade sistêmica sem um SOC 24/7 de retaguarda atrasa absurdamente os alertas de vazamento, tornando inviável comunicar Autoridades num prazo razoável legal (72 horas).

Art. 50

Governança & Boas Práticas

As abordagens amadoras de suporte (break/fix) sem processos documentados ou monitoramento central indicam negligência às regras orgânicas e à estruturação de compliance cibernético exigida na regulamentação.



Potenciais Sanções Administrativas

De acordo com provisões já efetivadas e aplicadas pela Autoridade Nacional de Proteção de Dados (ANPD) sobre vazamentos reais no Brasil, infrações por arquitetura exposta acarretarão em severas **multas limitadas a até 2% do faturamento da sua empresa** (no teto de R\$ 50

mi). Sem citar os incomensuráveis danos à imagem corporativa do da Nutrin Group ao mercado.

⬆ Como Mudar a História / Elevação de Maturidade

Esta é a simulação de resiliência caso os controles de postura avançada fornecidos pelo Grupo QOS (Concierge) sejam aderidos integralmente na fundação do ambiente:



Inspeção profunda de perímetro com prevenção de surpresas cibernéticas (NGFW)



Defesa baseada em IA e bloqueio real contra ransomware via Telemetria Endpoints (EDR)



Monitoramento Contínuo Residente e detecção em poucas horas(SOC Especialista 24/7)



Controles restritos de Identidade e Políticas Zero-Trust integradas (MFA/Segmentação)

Projeção do Score Arquitetônico:

52% → 92%

REDUÇÃO ABSOLUTA DA SUPERFÍCIE DE ATAQUE

Justificativa de Investimento e ROI

Comparação Risco Financeiro

ANTES (Situação Atual)

R\$ 67.500

DEPOIS (Modelo Concierge)

R\$ 22.500



Economia Estimada

Redução anual do passivo de risco após blindagem.

\$ R\$ 45.000
EVITADO AO ANO

Retorno (ROI Estimado)

Simulação interativa de impacto vs custo.

IMPLANTAÇÃO (R\$)

Ex: 5000

MENSALIDADE (R\$)

Ex: 2500

Estimativa base p/ seu cenário: R\$ 10.800 – R\$ 16.200 / mês

 Informe os valores acima para simular este cálculo.

Por que tecnologia isolada não resolve?

Apenas comprar licenças de softwares (Antivírus tradicionais ou Firewalls) gera uma falsa sensação de segurança. Sem **monitoramento unificado e ativo**, os alertas se perdem no ruído. Sem **capacidade humana de resposta**, malwares operam silenciosamente meses antes da contenção total.



O Modelo Gerenciado Concierge

Injetamos tecnologias Enterprise de ponta atreladas a um **SOC ativo 24/7**. Analistas especializados fazem o monitoramento contínuo e a resposta imediata a ameaças cibernéticas, esmagando o tempo de detecção de semanas para poucos minutos. Cuidamos do front-end da segurança para você cuidar do core do seu negócio.

 Como chegamos nesse valor? (Metodologia)

Maturidade Específica por Domínio

Firewall e Acesso

Proteção de rede e inspeção de borda interna / externa

Risco Alto

48

Endpoints

Proteção imutável nos dispositivos de usuários (Servidores/Wks)

Risco Alto

48

Backup e Resiliência

Cópias de segurança protegidas e continuidade rápida

Atenção

60



Como esse cálculo foi feito?

FINALIZAR DIAGNÓSTICO

Exporte todo o detalhamento executivo, matemático e de conformidade em um relatório otimizado para tomada de decisão (Business Case).



BAIXAR RELATÓRIO

